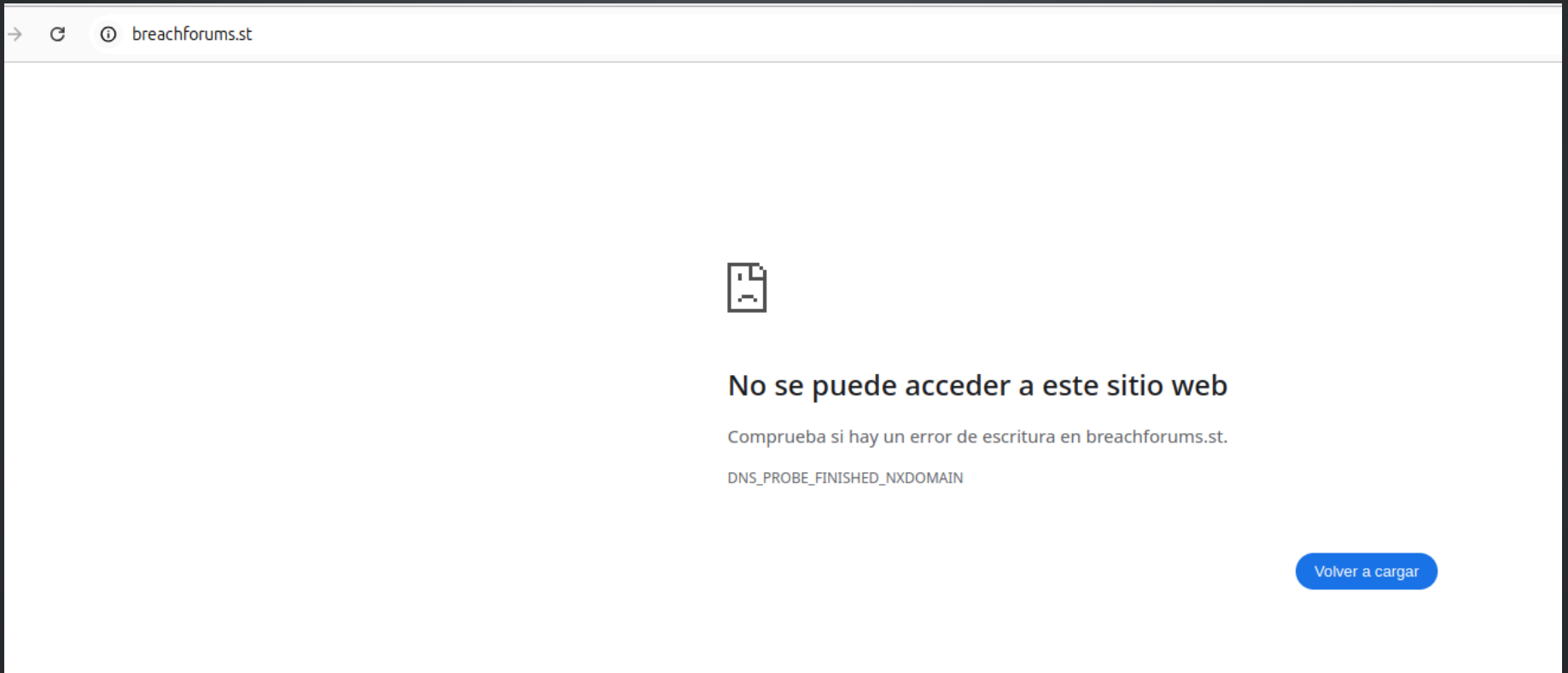


EN 2024:

- <https://breachforums.st/Thread-Argentina-API-working-SELLING?highlight=renaper>
- <https://breachforums.st/Thread-DOCUMENTS-ARGENTINA-RENAPER-168K-Simple?highlight=renaper>
- <https://breachforums.st/Thread-DOCUMENTS-ARGENTINA-RENAPER-680K?highlight=renaper>
- <https://breachforums.st/Thread-ARGENTINA-PAMI-INSTITUCIONAL-DATABASE-SHIT>
- <https://breachforums.st/Thread-SELLING-PlayCat-Selling-Argentina-Central-Bank-Customer-Database-9K-Lines>
- Bot en telegram @licenciasARbot

ESTA SEMANA:



➔ Forwarded from BF Repo V3 News

It seems like Breachforums is down for now and there are no replacements or new domains for it. Don't get scammed or tricked into a honeypot. Stay safe.



27



5

3,2K  09:38

➔ Forwarded from BF Repo V3 News

The current briefing of the situation is as follows

Shiny deleted his Telegram without saying anything to any of the Moderators.

Hollow was online yesterday but ignored any messages and changed his last seen settings.

At this point both Shiny and Hollow should be considered Sus until more information comes out.

source: *victim / addka / zjj*

Este tablón de anuncios está actualmente cerrado. El Administrador ha especificado el motivo a continuación.

Estimada comunidad: Como muchos de ustedes habrán notado, la infraestructura de BreachForums se desconectó repentinamente.

Esto se debió a un problema inesperado, principalmente porque Shiny, quien anteriormente administraba la infraestructura, ya no está en contacto y no hemos podido comunicarnos con él.

En vista de esto, hemos tomado la decisión de reconstruir desde cero.

Se ha preparado una infraestructura completamente nueva y usaremos una base de código fuente nueva y limpia. Esto garantiza que no existan puertas traseras desconocidas ni vulnerabilidades, intencionadas o no, de versiones anteriores.

La seguridad y la estabilidad son nuestras principales prioridades de cara al futuro. El nuevo foro estará disponible pronto.

Gracias por su paciencia y continuo apoyo. -

 Anastasia

Operación Phantom

(Protocolo de Contención Avanzada
- Eliminación Total de Huellas)*

Acciones Inmediatas

1. Ejecución de "Kill Switch"

- Sobreescritura de discos con
datos aleatorios en 3 capas (método
Gutmann modificado):

```
for i in {1..3}; do  
    dd if=/dev/urandom of=/dev/nvme0n1  
    bs=4M status=progress conv=notrunc  
done
```

- Destrucción de particiones:

```
sgdisk --zap-all /dev/nvme0n1
```

Cuando usar defensa de tierra quemada

1

Cuando eres la última línea de defensa

3

Cuando tiene datos valiosos que no puede dejar caer en las manos equivocadas

2

Cuando haya agotado todas las demás opciones

4

Cuando se enfrenta a una amenaza existencial

FasterCapital

Date Range (Approx.)	Forum Version / Key Domain(s)	Key Administrator(s) / Operators	Significant Event(s)	Status / Outcome
2015 - Feb 2022	RaidForums (<code>raidforums.com</code>)	"Omnipotent" (Diogo Santos Coelho)	Forum Operation	Active cybercrime market
Feb/Apr 2022	RaidForums (<code>raidforums.com</code>)	"Omnipotent"	Arrest of Admin; LE Seizure (Operation TOURNIQUET)	Forum Shut Down
Mar 2022	BreachForums v1 (<code>breached.vc</code> , <code>.to</code> , <code>.co</code>)	"Pompompurin" (Conor Fitzpatrick)	Forum Launch	Active, successor to RaidForums
Mar 15, 2023	BreachForums v1	"Pompompurin"	Arrest of Admin Fitzpatrick	Admin charged
Mar 21, 2023	BreachForums v1	"Baphomet" (as interim admin)	Forum Shut Down by Admin (Fear of LE compromise)	Forum Offline
Jun 2023	BreachForums v1 Domains (<code>breached.vc</code> , <code>.to</code> , <code>.co</code>)	N/A	Formal LE Domain Seizure	Domains display seizure notice
Jun 2023	BreachForums v2 (<code>breachforums.st</code> , <code>.cx</code> , <code>.is</code> , <code>.vc</code>)	"Baphomet", ShinyHunters	Forum Relaunch	Active, operating despite initial honeypot fears
May 15, 2024	BreachForums v2 (<code>breachforums.st</code> , <code>.onion</code> , Telegram)	"Baphomet", ShinyHunters	FBI/DOJ Seizure (Int'l Op); Admin Baphomet reported arrested	Site/Telegram seized; Backend data compromised
May 15-29, 2024	BreachForums v2 (<code>breachforums.st</code>)	ShinyHunters (reportedly)	Domain control regained; Site back online	Operational status contested (honeypot speculation)
Late 2024 (Reported)	BreachForums v2	IntelBroker (alleged new owner)	Leadership Change	Forum operation continues
Early 2025 (Reported)	BreachForums v2	"Anastasia" (alleged new owner)	Leadership Change (IntelBroker steps down)	Forum operation continues under new admin
Apr 15, 2025	BreachForums v2 (<code>breachforums.st</code>)	"Anastasia"	Site goes offline without notice	Outage begins
Apr 15-18, 2025	BreachForums v2 (Telegram)	"Anastasia", "ShinyHunter" (Mod), "Hollow" (Mod)	Admin Telegram compromised (redirects to FBI IC3); Mods disappear/go inactive	Strong indicators of LE action, but no official confirmation/seizure banner

BreachForums la evolución

EL TOPTEN

[HTTPS://OWASP.ORG/TOP10/ES/](https://owasp.org/top10/es/)

¿QUÉ ES MITRE?

- Organización que con fondos del estado de EEUU trabaja en aspectos de seguridad informática.
- Lo importante es que administra el índice de Common Vulnerabilities and Exposure (CVE), identificador mundialmente utilizado.
- Ej: CVE-2014-0160
- Common vulnerabilities Enumeration
- Common Weakness Enumeration-> Ejemplo

DATA FACTORS

- CWEs mapeadas: El número de CWEs asignadas a una categoría por el equipo del Top 10.
- Tasa de incidencia: La tasa de incidencia es el porcentaje de aplicaciones vulnerables a esa CWE de la población analizada por esa organización para ese año.
- Cobertura (de pruebas): El porcentaje de aplicaciones que han sido testadas por todas las organizaciones para una determinada CWE.
- Explotabilidad ponderada: La sub-puntuación de explotabilidad de las puntuaciones CVSSv2 y CVSSv3 asignadas a las CVEs mapeadas a las CWEs, normalizados y colocados en una escala de 10 puntos. [Calculadora](#)

DATA FACTORS

- Impacto ponderado: La sub-puntuación de Impacto de las puntuaciones CVSSv2 y CVSSv3 asignadas a las CVEs mapeadas a las CWEs, normalizados y colocados en una escala de 10 puntos.
- Total de ocurrencias: Número total de aplicaciones en las que se han encontrado las CWEs asignados a una categoría.
- Total de CVEs: Número total de CVEs en la base de datos del NVD que fueron asignadas a las CWEs asignados a una categoría.

RIESGOS: ¿QUÉ ANALIZA OWASP?

Agentes De Amenaza	Vectores De Ataque	Prevalencia de Debilidades	Detectabilidad de Debilidades	Impacto Técnico	Impacto Al Negocio
?	Fácil	Difundido	Fácil	Severo	?
	Medio	Común	Medio	Moderado	
	Difícil	Poco Común	Difícil	Menor	

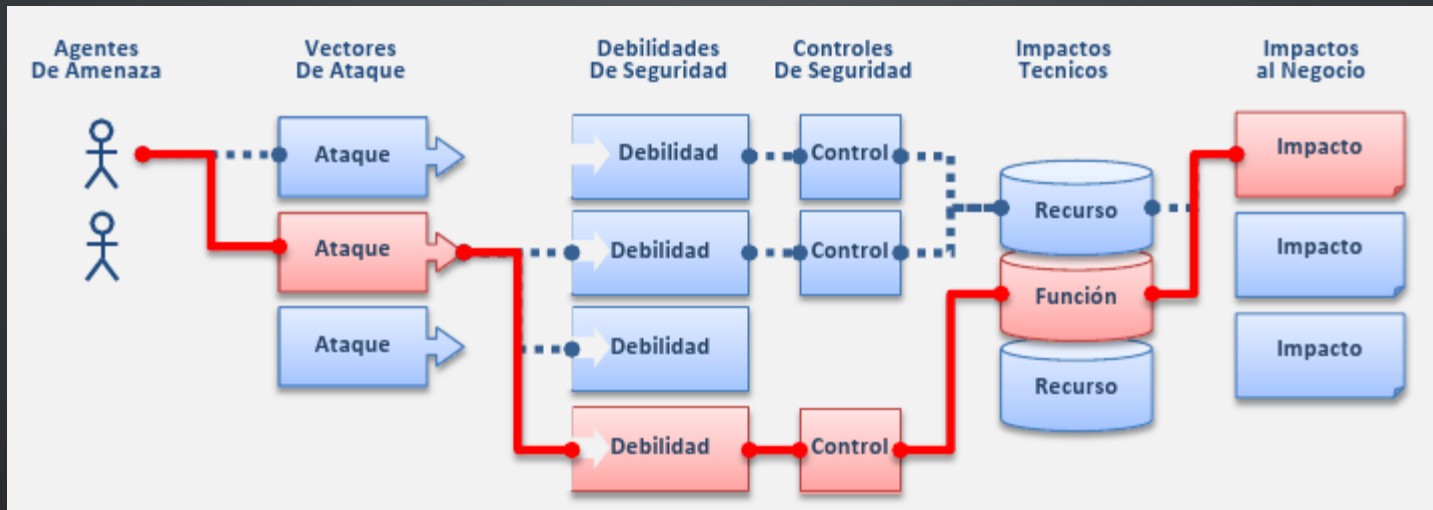
Sin embargo, solo usted sabe los detalles específicos de su ambiente y su negocio. Para una aplicación cualquiera, puede no haber un agente de amenaza que pueda ejecutar el ataque relevante, o el impacto técnico puede no hacer diferencia ninguna. Por tanto, usted debería evaluar cada riesgo, enfocándose en los agentes de amenaza, los controles de seguridad e impactos de negocio en su empresa.

EJEMPLO

- Recordemos por ejemplo el **Deface o defacement** manipular la página principal de un servidor web sin autorización, dejando algún tipo de mensaje en texto, imagen, vídeo...
- No siempre se trata de un motivo económico, puede ser de carácter reivindicativo político, lo que sería hacktivismo, o para avergonzar a los responsables del sitio, o simplemente un graffiti al estilo "estuve aquí".
- Por ejemplo en una fecha específica.

RIESGOS

- Los atacantes pueden potencialmente usar muchas diferentes rutas a través de su aplicación para causar daño.
- A veces, estas rutas son triviales de encontrar y explotar y a veces son extremadamente difíciles.
- De manera similar, el daño causado puede ir de ninguno hasta incluso sacarlo del negocio.
- Cada ruta es un riesgo



RIESGO TECNOLÓGICO

- Es la probabilidad de sufrir pérdidas por caídas o fallos en los sistemas informáticos o transmisión de datos, error desde programación u otros, siendo un componente del riesgo operativo

RIESGOS EN APLICACIONES

- Los atacantes pueden usar potencialmente rutas diferentes a través de la aplicación para hacer daño al negocio u organización, estas rutas representan un riesgo que puede, o no, ser lo suficientemente grave como para justificar la atención.

OWASP RISK RATING METHODOLOGY

Riesgo = Probabilidad de que ocurra * Impacto en el negocio

1. Identificar un Riesgo
2. Estimar la probabilidad
3. Estimar el impacto
4. Determinar la severidad del riesgo
5. Decidir que arreglar
6. Customizing Your Risk Rating Model

¿Cuál es mi riesgo según OWASP?

OWASP RISK RATING METHODOLOGY

Riesgo = Probabilidad de que ocurra * Impacto en el negocio

1. Identificar un Riesgo
2. Estimar la probabilidad
3. Estimar el impacto
4. Determinar la severidad del riesgo
5. Decidir que arreglar
6. Customizing Your Risk Rating Model

¿Cuál es mi riesgo según OWASP?

OWASP RRM: IDENTIFICAR EL RIESGO

- Muchas veces es el paso más difícil porque hay que identificar el riesgo que queremos medir.
- Habrá que reunir:
 - Información sobre los posibles **agentes** de amenaza
 - Identificar **vulnerabilidades** que pueden ser explotados por los agentes de amenaza.
 - Estimar el **impacto sobre el negocio** de una materialización de la amenaza.
- En general es mejor pensar en el peor caso posible.

OWASP RRM: ESTIMAR LA PROBABILIDAD

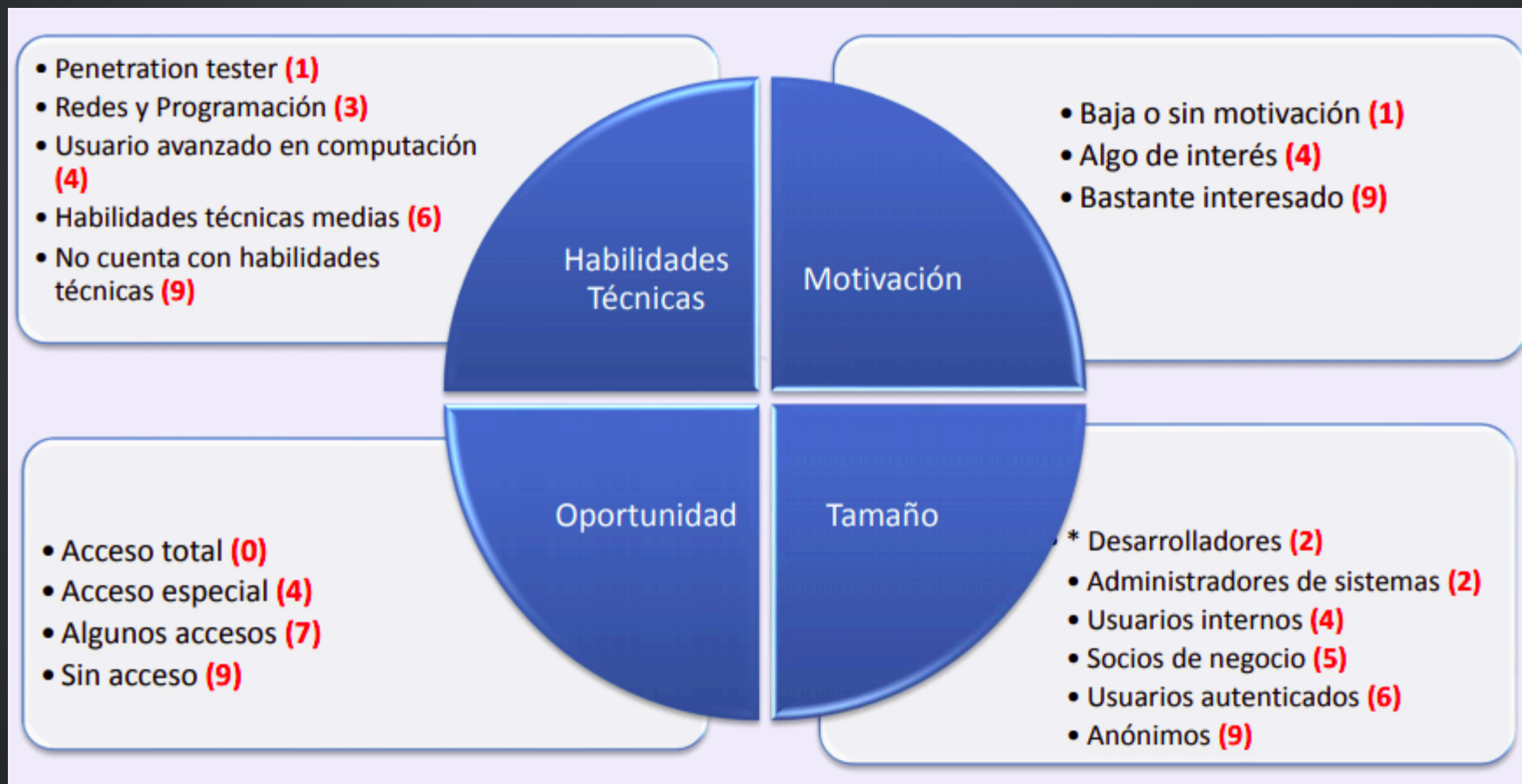
- Una vez identificados los riesgos, debe estimarse:
 - La probabilidad de que una vulnerabilidad en particular sea descubierta y explotada.
 - Para un calculo con mayor certeza es recomendable el calculo **cuantitativo**.

OWASP RRM: ESTIMAR LA PROBABILIDAD

- OWASP utiliza una serie de factores para realizar esta estimación de la probabilidad.
- Los mismos están asociados a dos conceptos: a el o los atacantes y a la vulnerabilidad.
- A cada factor se le asigna un valor entre 0 y 9.

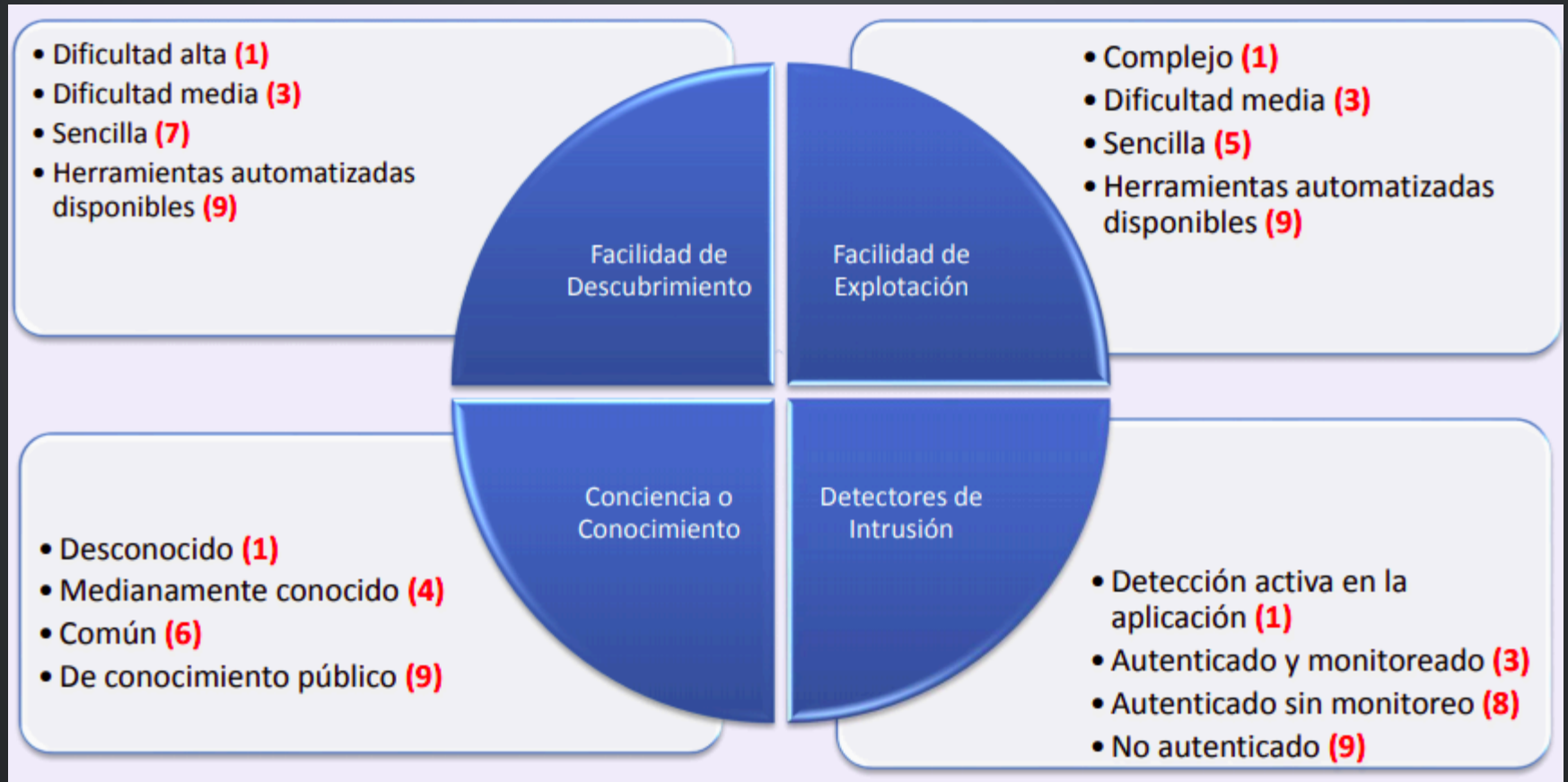
OWASP RRM: ESTIMAR LA PROBABILIDAD

- Agentes de amenazas:



OWASP RRM: ESTIMAR LA PROBABILIDAD

- Vulnerabilidades

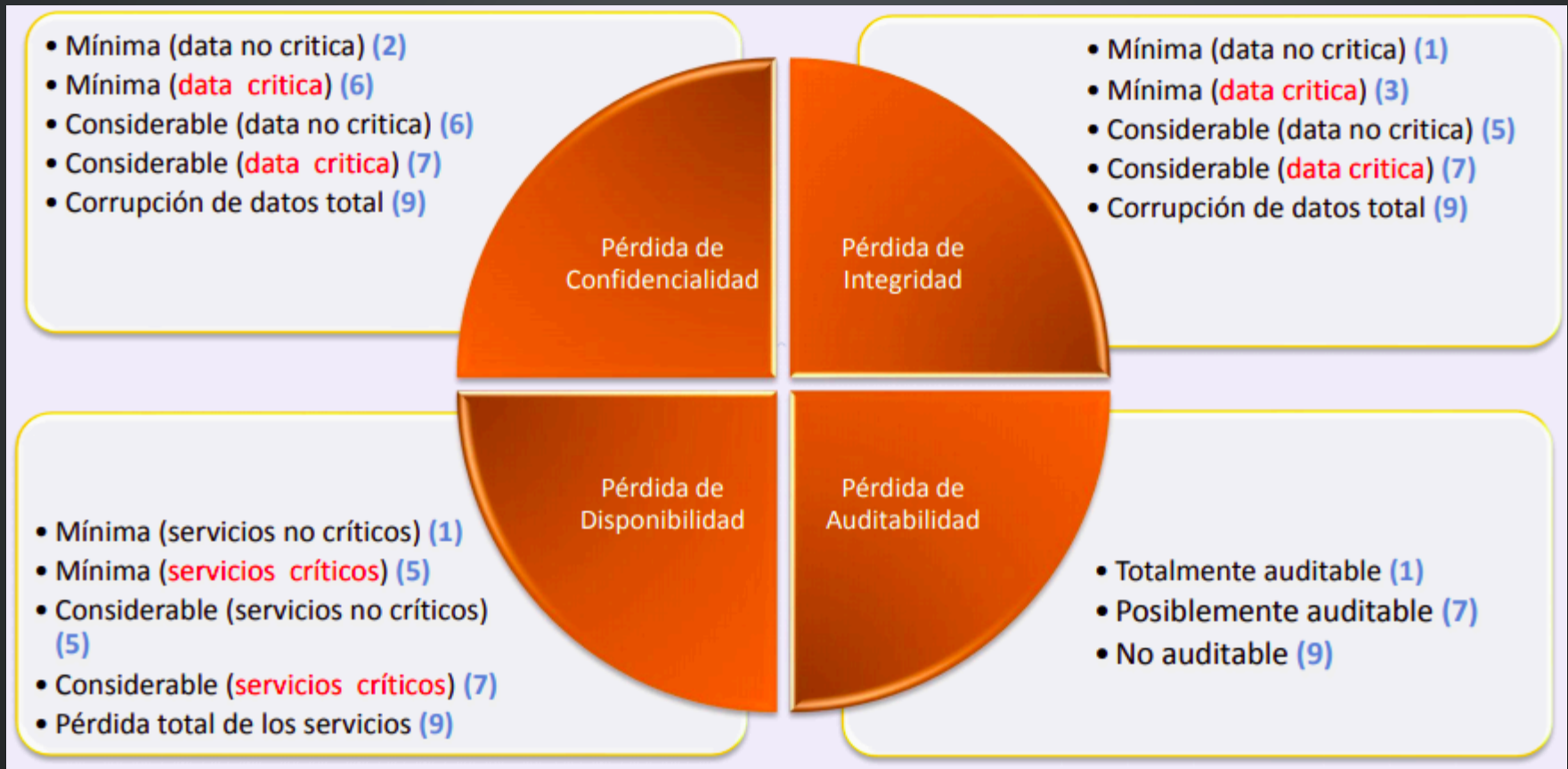


OWASP RRM: ESTIMAR EL IMPACTO

- Cuando una amenaza es materializada, deben considerarse dos tipos de impacto:
 - Impacto Técnico.
 - Impacto sobre el Negocio
- Al igual que en la estimación de la probabilidad de ocurrencia se utilizan valoración de factores.
- Nuevamente se asignan valores de 0 a 9 a cada uno de los factores

OWASP RRM: ESTIMAR EL IMPACTO

- Impacto técnico:



OWASP RRM: ESTIMAR EL IMPACTO

- Impacto negocio:



OWASP RRM: DETERMINAR SEVERIDAD DEL RIESGO

- Para determinar la severidad del riesgo, se debe trabajar con los siguientes valores:
 - **Probabilidad** de la ocurrencia de la amenaza.
 - **Impacto** generado sobre el negocio

Likelihood and Impact Levels	
0 to <3	LOW
3 to <6	MEDIUM
6 to 9	HIGH

OWASP RRM: DETERMINAR SEVERIDAD DEL RIESGO

- El primer paso es seleccionar una de las opciones asociadas con cada factor e ingresar el número asociado en la tabla.
- Luego, simplemente se toma el promedio de las puntuaciones para calcular la probabilidad general.
- Por ejemplo:

"Threat agent factors"					"Vulnerability factors"			
Skill level	Motive	Opportunity	Size		Ease of discovery	Ease of exploit	Awareness	Intrusion detection
5	2	7	1		3	6	9	2
Overall likelihood=4.375 (MEDIUM)								

OWASP RRM: DETERMINAR SEVERIDAD DEL RIESGO

- Mismo proceso que el anterior pero obtendremos dos valores, técnico y negocio

Technical Impact					Business Impact			
Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability		Financial damage	Reputation damage	Non-compliance	Privacy violation
9	7	5	8		1	2	1	5
Overall technical impact=7.25 (HIGH)					Overall business impact=2.25 (LOW)			

OWASP RRM: DETERMINAR SEVERIDAD DEL RIESGO

- Ahora podemos combinarlas para obtener una calificación de gravedad final para este riesgo.

Overall Risk Severity				
Impact	HIGH	Medium	High	Critical
	MEDIUM	Low	Medium	High
	LOW	Note	Low	Medium
		LOW	MEDIUM	HIGH
	Likelihood			

OWASP RRM: DETERMINAR SEVERIDAD DEL RIESGO

- En el ejemplo anterior, la **probabilidad** es **media** y el **impacto técnico** es **alto**, por lo que desde una perspectiva puramente técnica parece que la gravedad general es **alta**.
- Sin embargo, tenga en cuenta que el **impacto del negocio** es realmente **bajo**, por lo que la gravedad general también se describe mejor como **baja**.
- Esta es la razón por la que comprender el contexto del negocio de las vulnerabilidades que está evaluando es tan fundamental para tomar buenas decisiones de riesgo.
- No comprender este contexto puede provocar la falta de confianza entre el negocio y los equipos de seguridad que está presente en muchas organizaciones.

OWASP RRM: DECIDIR QUE ARREGLAR

- Al obtener esta clasificación ya tenemos una lista pesada de fix para realizar.
- En este paso hay que ver el negocio nuevamente, ¿tiene sentido arreglar algo que cuesta hacerlo 100 cuando la perdida que puede causar es de 2?
- ¿Y que ocurre si es de \$2 pero además afecta la imagen de la empresa?
- Como desarrolladores hay que plantar la idea ante la gerencia que indiquen estos costos asociados cuando se plantean estas cuestiones.

PERSONALIZAR EL MODELO DE CLASIFICACIÓN DE RIESGOS

- Existen varias maneras:
 - Agregando factores
 - Personalizando las opciones
 - Asignando peso a cada uno de los factores

CADA UNO TIENE QUE EVALUAR EL RIESGO



2015 - ASHLEYMADISCON

**ASHLEY
MADISON®**
Life is short. Have an affair.®



TIME'S UP!

Avid Life Media has failed to take down Ashley Madison and Established Men. We have explained the fraud, deceit, and stupidity of ALM and their members. Now everyone gets to see their data.

Find someone you know in here? Keep in mind the site is a scam with thousands of fake female profiles. See ashley madison fake profile lawsuit; 90-95% of actual users are male. Chances are your man signed up on the world's biggest affair site, but never had one. He just tried to. If that distinction matters.

Find yourself in here? It was ALM that failed you and lied to you. Prosecute them and claim damages. Then move on with your life. Learn your lesson and make amends. Embarrassing now, but you'll get over it.

#	Name	Size	Status	Health	Down Speed	Up Speed	ETA	Rating	Playback
1	dmips	9.69 GB	Downloading 4.4%		349.5 kB/s	111.1 kB/s	9h 27m	★★★★	

Path	Size	Done	%	# Pieces	Pieces	Priority	Rate	Reso
74ABAA38.txt	3.03 kB	0 B	0.0 %	1		normal		
am_am.dump.gz	2.59 GB	158 MB	5.9 %	1331		normal		
am_am.dump.gz.asc	836 B	0 B	0.0 %	1		normal		
aminno_member.dump.gz	3.03 GB	100 MB	3.2 %	1555		normal		
aminno_member.dump.gz.asc	836 B	0 B	0.0 %	1		normal		
aminno_member_email.dump.gz	438 MB	22.0 MB	5.0 %	220		normal		
aminno_member_email.dump.gz.asc	836 B	0 B	0.0 %	1		normal		
ashleymadison.dump.7z	36.0 MB	0 B	0.0 %	19		normal		
ashleymadison.dump.7z.asc	836 B	0 B	0.0 %	1		normal		
CreditCardTransactions.7z	277 MB	6.00 MB	2.1 %	140		normal		
CreditCardTransactions.7z.asc	836 B	0 B	0.0 %	1		normal		
member_details.dump.gz	703 MB	56.0 MB	7.9 %	353		normal		
member_details.dump.gz.asc	836 B	0 B	0.0 %	1		normal		
member_login.dump.gz	2.63 GB	88.0 MB	3.2 %	1351		normal		
member_login.dump.gz.asc	836 B	0 B	0.0 %	1		normal		
README	1.15 kB	0 B	0.0 %	1		normal		
README.asc	836 B	0 B	0.0 %	1		normal		

2015 - ASHLEYMADISON

Dominio	Cantidad
mendoza.gov.ar	16
mecon.gob.ar	9
buenosaires.gob.ar	7
senasa.gov.ar	6
afip.gob.ar	5
osep.mendoza.gov.ar	4
trabajo.gob.ar	4
arba.gov.ar	3
cnea.gov.ar	3
jusbaires.gov.ar	3
juschubut.gov.ar	3
minplan.gov.ar	3
anac.gov.ar	2

Nota Seguinfo

HECHOS DETERMINANTES - RIESGO

- Torres gemelas: 11 de septiembre de 2001
- Fukushima : 11 de marzo de 2011
 - Alemania cierra reactores 1
 - Alemania cierra reactores 2

ACÁ ESTAMOS MUY LEJOS DE JAPON!

las billeteras virtuales

Inicio • Economía • Obra Pública 12 de diciembre 2022 - 21:56

Carem: la construcción de la "mini" central nuclear argentina superó el 75% de la obra

Por Florencia Barragan

El Gobierno aspira a terminar la obra a fines de 2024. El reactor tiene una tecnología que solo realizan tres países. La crisis de Europa y la transición energética abren una oportunidad para la energía nuclear.

- Plan motosierra: Javier Milei aseguró que recortará 13 puntos del gasto público y que cerrará las empresas del Estado
- 30 meses consecutivos: la obra pública sostiene el crecimiento del empleo



AMÉRICA LATINA

Argentina y China firman contrato para construir una central nuclear

Argentina ya posee otras tres centrales nucleares que aportan hasta el 7,5% de la energía eléctrica en el país.



China, segundo social comercial de Argentina, proveerá la ingeniería, construcción, adquisición, puesta en marcha y entrega de Atucha III, cuyo reactor utilizará uranio enriquecido como combustible y agua liviana como refrigerante y moderador (Foto de archivo).

Argentina y China firmaron el martes (01.02.2022) un contrato para la construcción de una cuarta central nucleoelectrica en el país sudamericano con una inversión de 8.000 millones de dólares, informó la agencia pública de noticias Tólam.

(2014 - Carem) (2022 - Atucha III)

AH...PERO...LA GUERRA EN UCRANIA

FAMOSO
Lo reconocen todas las billeteras virtuales

COMISION 0%
EN TRANSFERENCIAS INMEDIATAS

EL MUNDO

Japón planea construir reactores nucleares de nueva generación

En un giro de la política energética del país después de la catástrofe de Fukushima, el primer ministro Fumio Kishida anunció que se volverá a apostar por la energía atómica ante la actual crisis energética.





© Shohei Miyano/Kyodo News/AP/picture alliance

Imagen reciente de la central nuclear de Fukushima Daiichi

Petroleo muy caro

LA CALCULADORA PARA LAS VULNERABILIDADES - CVSS

- The Common Vulnerability Scoring System (CVSS) provides a way to capture the principal characteristics of a vulnerability and produce a numerical score reflecting its severity. The numerical score can then be translated into a qualitative representation (such as low, medium, high, and critical) to help organizations properly assess and prioritize their vulnerability management processes.
- <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator?vector=AV:N/AC:H/PR:H/UI:R/S:U/C:N/I:N/A:H>

FIRST

- FIRST is the global Forum of Incident Response and Security Teams
- "Comunidad / Foro mundial" de los más importantes del mundo en cuestiones de ciberseguridad y sobre todo gestión de incidentes
- Tools: <https://www.first.org/cvss/calculator/4-0>

TENABLE Y SEVERIDADES

Tenable recommends managing expectations around SLAs and developing specific plans accordingly regarding switching to CVSSv3.

CVSSv2 vs CVSSv3 Severity:

	CVSSv2 Base Score Range	CVSSv3 and CVSSv4 Base Score Range
None	n/a	0.0
Low	0.0 - 3.9	0.1 - 3.9
Medium	4.0 - 6.9	4.0 - 6.9
High	7.0 - 9.9	7.0 - 8.9
Critical	10.0*	9.0 - 10.0

*CVSSv2 does not officially have a Critical severity rating. Tenable defines a CVSSv2 base score of 10.0 as Critical

OWASP: WEB SECURITY TESTING GUIDE

- La WSTG ([Web Security Testing Guide](#)) nace en el año 2013 como una guía complementaria al OWASP TOP 10.
- Este documento provee información más específica y técnica sobre los controles de seguridad que se deben contemplar a la hora de realizar pentesting en aplicaciones web.
- Además, a la WSTG se le suma un complemento llamado [OWASP Web Application Penetration Checklist](#) que nos ayudara a contabilizar y categorizar los controles de seguridad que debemos ejecutar según OWASP TOP 10 y la información de la WSTG.

OWASP: WEB SECURITY TESTING GUIDE

- La WSTG ([Web Security Testing Guide](#)) nace en el año 2013 como una guía complementaria al OWASP TOP 10.
- Este documento provee información más específica y técnica sobre los controles de seguridad que se deben contemplar a la hora de realizar pentesting en aplicaciones web.
- Además, a la WSTG se le suma un complemento llamado [OWASP Web Application Penetration Checklist](#) que nos ayudara a contabilizar y categorizar los controles de seguridad que debemos ejecutar según OWASP TOP 10 y la información de la WSTG.

OWASP: WEB SECURITY TESTING GUIDE

- El objetivo del proyecto es ayudar a comprender el qué , por qué , cuándo , dónde y cómo testear aplicaciones web.
- El proyecto ha proporcionado un marco de prueba completo, no una simple lista de verificación o prescripción de problemas que deben abordarse.
- Los lectores pueden utilizar este marco como plantilla para crear sus propios programas de testing.
- La WSTG describe en detalle tanto el marco de prueba general como las técnicas necesarias para implementar el marco en la práctica.

OWASP: WEB SECURITY TESTING GUIDE

- El método de testing seguridad de aplicaciones web de OWASP se basa en el enfoque de caja negra.
- El tester no sabe nada o tiene muy poca información sobre la aplicación que se va a testear.
- Es muy útil para enfocar un pentest de manera organizada o utilizarlo en pruebas de caja blanca cómo guía para testear de manera organizada.

OWASP: WSTG

OWASP TOP 10

OWASP Top 10 - 2017
A1:2017-Injection
A2:2017-Broken Authentication
A3:2017-Sensitive Data Exposure
A4:2017-XML External Entities (XXE)
A5:2017-Broken Access Control
A6:2017-Security Misconfiguration
A7:2017-Cross-Site Scripting (XSS)
A8:2017-Insecure Deserialization
A9:2017-Using Components with Known Vulnerabilities
A10:2017-Insufficient Logging & Monitoring



OWASP WSTG



OWASP WebApplication Checklist

OWASP: Testing Guide v4.2 Checklist				
Information Gathering	Test Name	Objective	Status	Notes
1	WSTG-INFO-01	Conduct Search Engine (Discovery) Reconnaissance for Information Leakage	Not Started	
2	WSTG-INFO-02	Fingerprint Web Server	Not Started	
3	WSTG-INFO-03	Review Webserver Metadata for Information Leakage	Not Started	
4	WSTG-INFO-04	Enumerate Applications on Webserver	Not Started	
5	WSTG-INFO-05	Review Webpage Content for Information Leakage	Not Started	
6	WSTG-INFO-06	Identify application entry points	Not Started	
7	WSTG-INFO-07	Map execution paths through application	Not Started	
8	WSTG-INFO-08	Enumerate Web Application Framework	Not Started	

OWASP APPLICATION SECURITY VERIFICATION STANDARD (ASVS)

- El Estándar de Verificación de Seguridad de Aplicaciones de **OWASP ASVS** es una lista de requisitos o pruebas de seguridad de aplicaciones que los arquitectos, desarrolladores, evaluadores, profesionales de la seguridad e incluso los consumidores pueden utilizar para definir qué constituye una aplicación segura.

OWASP ASVS

- OWASP ASVS ofrece una lista completa de requisitos, controles y pruebas de seguridad de aplicaciones web que puede utilizar para determinar el alcance, crear y verificar aplicaciones web y móviles seguras.
- Permite a las organizaciones desarrollar y mantener aplicaciones más seguras; y también brinda a los proveedores de servicios de seguridad y proveedores un conjunto de controles bien documentado con el que pueden alinear sus requisitos y ofertas.
- La última versión, OWASP ASVS v4.0.2, se lanzó en octubre de 2020.

OWASP ASVS

- Tiene como objetivo fijar un standard para normalizar el nivel y el rigor con el que se hacen las verificaciones de seguridad sobre aplicaciones webs.
- La idea es que :
 - Se use como métrica para dar un valor de confianza a las aplicaciones
 - Se use como guía para los desarrolladores puedan construir controles de manera de satisfacer los requisitos de seguridad de la aplicación
 - Se use durante adquisiciones proveyendo una base para especificar requerimientos de seguridad en los contratos

OWASP ASVS: NIVELES



- El estándar para la verificación de seguridad en aplicaciones define tres niveles de verificación para la seguridad, con cada nivel incrementando su profundidad.
 - ASVS Nivel 1 es para todo el software.
 - ASVS Nivel 2 es para las aplicaciones conteniendo datos sensibles, los cuales requieren protección.
 - ASVS Nivel 3 es para las aplicaciones más críticas, aplicaciones realizando transacciones de alto valor, conteniendo datos médicos sensibles, o cualquier aplicación el cual requiera un alto nivel de confianza.

OWASP ASVS: NIVELES

- Cada nivel del ASVS contiene una lista de requerimientos para la seguridad.
- Cada uno de estos requerimientos puede también ser mapeado hacia características y capacidades específicas en seguridad, los cuales deben ser construidos en el software por los desarrolladores.
- **OWASP ASVS**

A01-2021: PÉRDIDA DE CONTROL DE ACCESO

- Sube de la quinta posición a la categoría con el mayor riesgo en seguridad de aplicaciones web
- El 3,81% de las aplicaciones probadas tenían una o más Common Weakness Enumerations (CWEs) con más de 318.000 ocurrencias de CWEs en esta categoría de riesgo.
- Las 34 CWEs relacionadas con la Pérdida de Control de Acceso tuvieron más apariciones en las aplicaciones que cualquier otra categoría.

A01-2021 - PÉRDIDA DE CONTROL DE ACCESO

Las CWE (Common Weakness Enumerations) más importantes incluidas son:

- **CWE-200**: Exposición de información sensible a un actor no autorizado
- **CWE-201**: Exposición de información confidencial a través de datos enviados
- **CWE-352**: Falsificación de Peticiones en Sitos Cruzados (Cross Site Request Forgery, CSRF por su siglas en inglés).

A01-2021 - PÉRDIDA DE CONTROL DE ACCESO

- Las restricciones sobre lo que los usuarios autenticados pueden hacer no se aplican correctamente.
- Los atacantes pueden explotar estos defectos para acceder, de forma no autorizada, a funcionalidades y/o datos, cuentas de otros usuarios, ver archivos sensibles, modificar datos, cambiar derechos de acceso y permisos, etc.

A01-2021 - PÉRDIDA DE CONTROL DE ACCESO

- Violación del principio de mínimo privilegio o denegación por defecto, según el cual el acceso sólo debe ser permitido para capacidades, roles o usuarios particulares, y no disponible para cualquier persona.
- Eludir las comprobaciones de control de acceso modificando la URL (alteración de parámetros o navegación forzada), el estado interno de la aplicación o la página HTML, o mediante el uso de una herramienta que modifique los pedidos a APIs.
- Permitir ver o editar la cuenta de otra persona, con tan solo conocer su identificador único (referencia directa insegura a objetos)
- Acceder a APIs con controles de acceso inexistentes para los métodos POST, PUT y DELETE.

A01-2021 - PÉRDIDA DE CONTROL DE ACCESO

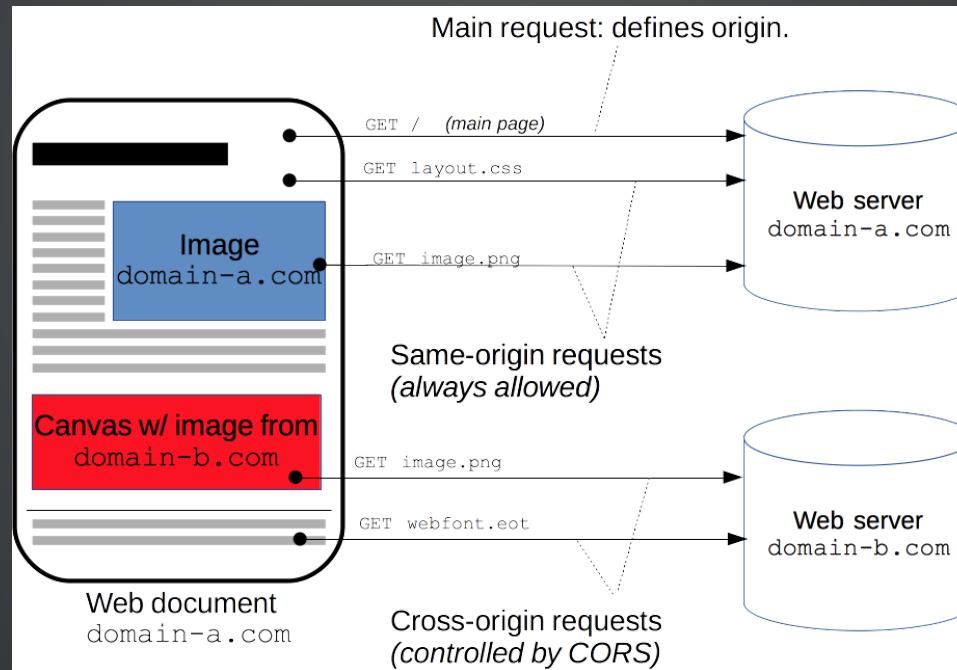
- Elevación de privilegios. Actuar como usuario sin haber iniciado sesión o actuar como administrador cuando se inició sesión como usuario regular.
- Manipulación de metadatos, como reutilizar o modificar un token de control de acceso JSON Web Token (JWT), una cookie o un campo oculto, manipulándolos para elevar privilegios o abusar de la invalidación de tokens JWT.
- Configuraciones incorrectas de CORS (uso compartido de recursos de origen cruzado) que permiten el acceso a APIs desde orígenes no autorizados o confiables.
- Forzar la navegación a páginas autenticadas siendo usuario no autenticado o a páginas privilegiadas siendo usuario regular.

CONTROL DE ACCESO HTTP (CORS)

- Mecanismo que utiliza cabeceras HTTP adicionales para permitir que un user agent (en-US) obtenga permiso para acceder a recursos seleccionados desde un servidor, en un origen distinto.
- Un agente crea una petición HTTP de origen cruzado cuando solicita un recurso desde un dominio distinto, un protocolo o un puerto diferente al del documento que lo generó.
- Un ejemplo de solicitud de origen cruzado: el código JavaScript frontend de una aplicación web que es localizada en <http://domain-a.com> utiliza XMLHttpRequest para cargar el recurso <http://api.domain-b.com/data.json>.

CONTROL DE ACCESO HTTP (CORS)

- Por razones de seguridad, los exploradores restringen las solicitudes HTTP de origen cruzado iniciadas dentro de un script



CORS EJEMPLO

- Ejemplo CORS
- Mozilla observatory

A01-2021 - PÉRDIDA DE CONTROL DE ACCESO

A01-2021 - EJEMPLOS #1

- La aplicación utiliza datos no verificados en una llamada SQL que accede a información de una cuenta:

```
pstmt.setString(1, request.getParameter("acct"));  
ResultSet results = pstmt.executeQuery( );
```

- Un atacante simplemente modifica el parámetro 'acct' en el navegador para enviar el número de cuenta que desee. Si no es verificado correctamente, el atacante puede acceder a la cuenta de cualquier usuario.

```
https://example.com/app/accountInfo?acct=notmyacct
```

A01-2021 - EJEMPLOS #2

- El atacante se dirige a las siguientes urls donde se requiere autenticación y especialmente permisos de admin para acceder a “admin_getappInfo”.
 - <http://example.com/app/getappInfo>
 - http://example.com/app/admin_getappInfo
- Si un usuario sin autenticarse puede acceder entonces hay una vulnerabilidad, al igual que si se logró acceder a admin_getappInfo sin permisos de admin también hay un problema.

A01-2021 - EJEMPLOS

- Accediendo a <https://catedras.linti.unlp.edu.ar/course/view.php?id=1287> podemos ver el curso de DSA al que todos tenemos permisos para ver.
- Si cambiamos el parametro "id" de la url no deberiamos poder ver el contenido de otro curso al que no estamos matriculados

A01-2021 - EJEMPLOS

- El caso whopper

A01-2021: REFERENCIA DIRECTA INSEGURA A OBJETOS

- Una referencia directa a un objeto ocurre cuando un desarrollador expone una referencia a la implementación interna de un objeto (archivo, directorio, registro de base de datos, una clave, URL o parámetro de un formulario).
- Un atacante puede manipular la referencia para acceder a objetos sin autorización, al menos que exista un control.

A01-2021: REFERENCIA DIRECTA INSEGURA A OBJETOS

- Un atacante, como usuario autorizado en el sistema, simplemente modifica el valor de un parámetro que se refiere directamente a un objeto del sistema a otro objeto para el que el usuario no se encuentra autorizado. ¿Se concede el acceso?
- Las aplicaciones no siempre verifican que el usuario tiene autorización sobre el objetivo.

A01-2021: RIESGO

					
App. Específica	Explotabilidad: 2	Prevalencia: 2	Detectabilidad: 2	Técnico: 3	¿Negocio?
La explotación del control de acceso es una habilidad esencial de los atacantes. Las herramientas SAST y DAST pueden detectar la ausencia de controles de acceso pero, en el caso de estar presentes, no pueden verificar si son correctos. Es detectable utilizando medios manuales o de forma automática en algunos <i>frameworks</i> que carecen de controles de acceso.		Las debilidades del control de acceso son comunes debido a la falta de detección automática y a la falta de pruebas funcionales efectivas por parte de los desarrolladores de aplicaciones. La detección de fallas en el control de acceso no suele ser cubierto por pruebas automatizadas, tanto estáticas como dinámicas.		El impacto técnico incluye atacantes anónimos actuando como usuarios o administradores; usuarios que utilizan funciones privilegiadas o crean, acceden, actualizan o eliminan cualquier registro. El impacto al negocio depende de las necesidades de la aplicación y de los datos.	

A01-2021: REFERENCIAS

- OWASP Proactive Controls: Enforce Access Controls
- OWASP Testing Guide: Authorization Testing
- OWASP Cheat Sheet: Access Control

C7: APLICAR CONTROLES DE ACCESO

C7: APLICAR CONTROLES DE ACCESO

- El control de acceso (o autorización) es el proceso de otorgar o denegar solicitudes específicas de un usuario, programa o proceso.
- El control de acceso también implica el acto de otorgar y revocar esos privilegios .

C7: APLICAR CONTROLES DE ACCESO

- Hay varios tipos diferentes de diseño de control de acceso que se deben considerar.
 - El control de acceso discrecional (Discretionary Access Control (DAC)) es un medio para restringir el acceso a objetos (por ejemplo, archivos, entidades de datos) en función de la identidad y la necesidad de conocer de los sujetos (por ejemplo, usuarios, procesos) y / o grupos a los que pertenece el objeto.
 - El control de acceso obligatorio (Mandatory Access Control(MAC)) es un medio de restringir el acceso a los recursos del sistema en función de la sensibilidad (representada por una etiqueta) de la información contenida en el recurso del sistema y la autorización formal (es decir, autorización) de los usuarios para acceder a la información de tal sensibilidad.

C7: APLICAR CONTROLES DE ACCESO

- El control de acceso basado en roles (Role Based Access Control (RBAC)) es un modelo para controlar el acceso a los recursos donde las acciones permitidas sobre los recursos se identifican con roles en lugar de con identidades de sujetos individuales.
- El Control de acceso basado en atributos (Attribute Based Access Control (ABAC)) otorgará o denegará las solicitudes de los usuarios en función de los atributos arbitrarios del usuario y los atributos arbitrarios del objeto, y las condiciones ambientales que pueden ser reconocidas globalmente y más relevantes para las políticas en cuestión

C7: PRINCIPIOS

- 1 - Diseñe el control de acceso a fondo
 - El control de acceso es una de las áreas principales del diseño de seguridad de aplicaciones que debe diseñarse minuciosamente desde el principio, especialmente cuando se abordan requisitos como el control de acceso de múltiples usuarios
 - El diseño del control de acceso puede comenzar simple, pero a menudo puede convertirse en un control de seguridad complejo y con muchas funciones
 - Al evaluar la capacidad de control de acceso de los frameworks de software, asegúrese de que su funcionalidad de control de acceso permita la personalización para sus necesidades específicas de funciones de control de acceso.

C7: PRINCIPIOS

- 2- Forzar que todas las solicitudes pasen por controles de control de acceso
 - Asegúrese de que todas las solicitudes pasen por algún tipo de capa de verificación de control de acceso
 - Las tecnologías como los filtros Java u otros mecanismos de procesamiento automático de solicitudes son artefactos de programación ideales que ayudarán a garantizar que todas las solicitudes pasen por algún tipo de verificación de control de acceso.

C7: PRINCIPIOS

- 3- Denegar por defecto
 - Denegar por defecto es el principio de que si una solicitud no se permite específicamente, se rechaza
 - Algunos ejemplos de estos son:
 - El código de la aplicación puede generar un error o una excepción al procesar las solicitudes de control de acceso. En estos casos, siempre se debe negar el control de acceso.
 - Cuando un administrador crea un nuevo usuario o un usuario se registra para una nueva cuenta, esa cuenta debe tener un acceso mínimo o nulo de forma predeterminada hasta que se configure ese acceso.
 - Cuando se agrega una nueva función a una aplicación, se debe negar a todos los usuarios el uso de esa función hasta que esté configurada correctamente.

C7: PRINCIPIOS

- 4 - Principio de mínimo privilegio
 - Asegúrese de que a todos los usuarios, programas o procesos se les proporcione el mínimo acceso necesario posible.
 - Tenga cuidado con los sistemas que no proporcionan capacidades de configuración de control de acceso granular.

C7: PRINCIPIOS

- 5 - No codifique roles
 - Muchos marcos de aplicaciones tienen de forma predeterminada un control de acceso basado en roles.
 - Es común encontrar un código de aplicación que esté lleno de comprobaciones de esta naturaleza.

```
if (user.hasRole("ADMIN")) || (user.hasRole("MANAGER")) {  
deleteAccount(); }
```

C7: PRINCIPIOS

- La programación basada en roles de esta naturaleza es frágil.
- Es fácil crear comprobaciones de roles incorrectas o faltantes en el código.
- La programación basada en roles no permite la tenencia múltiple.
- Se requerirán medidas extremas como bifurcar el código o verificaciones adicionales para cada cliente para permitir que los sistemas basados en roles tengan diferentes reglas para diferentes clientes.
- Las bases de código grandes con muchas comprobaciones de control de acceso pueden ser difíciles de auditar o verificar la política general de control de acceso de la aplicación

C7: PRINCIPIOS

- En su lugar, considere la siguiente metodología de programación de control de acceso:

```
if (user.hasAccess("DELETE_ACCOUNT")) { deleteAccount(); }
```

- Las comprobaciones de control de acceso basadas en atributos o características de esta naturaleza son el punto de partida para construir sistemas de control de acceso bien diseñados y ricos en funciones.
- Este tipo de programación también permite una mayor capacidad de personalización del control de acceso a lo largo del tiempo.

C7: PRINCIPIOS

- 6 - Registrar todos los eventos de control de acceso
 - Todas las fallas de control de acceso deben registrarse, ya que pueden indicar que un usuario malintencionado está investigando la aplicación en busca de vulnerabilidades.

UN EJEMPLO REAL

- Coinbase pays out largest bug bounty ever for trading interface flaw The researcher who discovered the issue was paid \$250,000.
- Coinbase